

TDD and BDD Test Cases for HealthCare Plus Appointment Booking

Requirement ID: REQ-APPT-01 "Valid patients must book appointments using their PatientID and credentials. Invalid booking attempts (for example, unauthorized users, unavailable times) must be rejected with a clear error message. After three failed attempts, the system restricts further bookings for a set period."

1. TDD Test Objective

Test Objective: Booking Restriction Logic Validation

Developer-Facing Test Objective:

Test Name: testBookingRestrictionAfterThreeFailedAttempts()

Objective: Verify that the appointment booking system correctly implements the three-strike restriction mechanism by:

- Tracking failed booking attempts per PatientID
- Incrementing failure count on invalid credentials or unauthorized access
- Blocking further booking attempts after exactly three failures
- Enforcing restriction period (configurable timeout)
- Clearing restriction after timeout expires
- Maintaining audit trail for security compliance

Input: PatientID with sequential failed booking attempts

Expected Outcome: Temporary booking restriction activated after third failure

Business Rule Validation: REQ-APPT-01 - Failed attempt lockout mechanism

Technical Implementation Requirements:

- Method should return `BookingResult.RESTRICTED` after 3rd failed attempt
 - Restriction period should be configurable (default: 30 minutes)
 - Failed attempt counter should reset after successful booking
 - All attempts must be logged for HIPAA audit compliance
-

2. BDD Scenarios (Gherkin Syntax)

Scenario 1: Successful Appointment Booking

gherkin

Feature: Patient Appointment Booking

As a registered patient

I want to book medical appointments online

So that I can schedule healthcare visits conveniently

Scenario: Valid patient successfully books appointment

Given I am a registered patient with PatientID "P12345"

And my credentials are valid and current

And I have provided HIPAA consent

And there are available appointment slots

When I enter my PatientID "P12345"

And I enter my valid credentials

And I select an available time slot "2024-03-15 10:00 AM"

And I submit the booking request

Then the appointment should be successfully booked

And I should receive a booking confirmation with appointment ID

And I should receive a HIPAA privacy notice

And the appointment should appear in my patient portal

And an audit log entry should be created

Scenario 2: Booking with Unauthorized PatientID

gherkin

Scenario: Unauthorized PatientID booking attempt

Given I have entered PatientID "INVALID123"

And this PatientID does not exist in the system

When I attempt to book an appointment

And I enter any credentials

And I submit the booking request

Then the booking should be rejected

And I should see error message "Unauthorized access. Invalid PatientID. Please verify your information or contact support."

And no appointment should be created

And no patient data should be displayed

And the failed attempt should be logged for security monitoring

And the attempt counter for this PatientID should increment by 1

Scenario 3: Booking Restriction After Three Failed Attempts

Scenario: Booking restriction enforced after three failed attempts

Given I am using PatientID "P67890"

And I have already made 2 failed booking attempts

When I make a third failed booking attempt with invalid credentials

And I submit the booking request

Then the booking should be rejected

And I should see error message "Account temporarily restricted due to multiple failed attempts. Please try again"

And the PatientID "P67890" should be temporarily blocked from booking

And any subsequent booking attempts should be immediately rejected

And the restriction should automatically expire after 30 minutes

And all failed attempts should be logged in the security audit trail

And the system should send an alert to the security monitoring team

Scenario: Booking allowed after restriction period expires

Given PatientID "P67890" was restricted due to failed attempts

And the 30-minute restriction period has elapsed

When I attempt to book an appointment with valid credentials

Then the restriction should be automatically lifted

And the booking attempt should proceed normally

And the failed attempt counter should be reset to zero

3. Edge Case Considerations

Edge Case 1: Valid PatientID with Unavailable Time Slot

Risk: System might incorrectly count scheduling conflicts as failed authentication attempts **Testing Gap:**

- What if a patient enters valid PatientID but selects an unavailable time slot?
- Should this count toward the 3-attempt restriction limit?
- **Recommendation:** Distinguish between authentication failures and booking conflicts
- **Test Scenario:** Failed booking due to time conflict should NOT increment restriction counter

Edge Case 2: Session Management and Page Refresh

Risk: Browser refresh or session interruption might reset or duplicate attempt counters **Testing Gap:**

- What happens if the booking page is refreshed after two failed attempts?
- Are failed attempts tracked server-side or client-side?
- **Recommendation:** Implement server-side attempt tracking with session correlation
- **Test Scenario:** Page refresh after 2 failed attempts should maintain attempt counter state

Edge Case 3: Automated Attack Prevention

Risk: Malicious bots could exploit the system or bypass security restrictions **Testing Gap:**

- Can bots submit rapid booking requests to bypass restrictions?
 - Are there rate limiting mechanisms beyond the 3-attempt rule?
 - **Recommendation:** Implement CAPTCHA, rate limiting, and IP-based monitoring
 - **Test Scenarios:**
 - Multiple rapid requests from same IP should trigger additional security measures
 - Bot detection should prevent automated credential stuffing attacks
 - Failed attempts from different IPs using same PatientID should aggregate
-

4. Additional Technical Edge Cases

Edge Case 4: Concurrent Session Management

Risk: Patient logged in from multiple devices simultaneously **Testing Gap:** How does the system handle failed attempts across multiple active sessions? **Recommendation:** Track attempts per PatientID regardless of session/device

Edge Case 5: System Clock Manipulation

Risk: Restriction period bypass through server time changes **Testing Gap:** What if system time is modified during restriction period? **Recommendation:** Use UTC timestamps and validate time progression

Edge Case 6: Database Connection Failures

Risk: Failed attempt counter might not persist during database issues **Testing Gap:** How are attempts tracked during system outages? **Recommendation:** Implement persistent storage with transaction rollback protection

5. Analyst Contributions Summary

These TDD and BDD test cases provide comprehensive coverage for the HealthCare Plus appointment booking system by establishing clear, testable requirements that bridge business needs with technical implementation. The TDD objective gives developers specific validation criteria for the security restriction logic, while the BDD scenarios describe user-facing behaviors in plain language that stakeholders can verify. Together, these test cases ensure reliable HIPAA-compliant functionality by covering both positive user flows and critical security edge cases, enabling the development team to build robust authentication controls while providing clear acceptance criteria for QA validation.

6. Implementation Recommendations

For Development Team:

1. Implement server-side attempt tracking with Redis/database persistence
2. Create configurable restriction periods for different environments
3. Add comprehensive audit logging for all booking attempts
4. Implement rate limiting and bot detection mechanisms

For QA Team:

1. Execute BDD scenarios using automated testing frameworks
2. Validate TDD objectives through unit test coverage
3. Perform security testing for edge cases identified
4. Verify HIPAA compliance through data handling validation

For Business Stakeholders:

1. Review BDD scenarios to confirm business logic accuracy
2. Validate error messages for user-friendliness and compliance
3. Approve restriction timeframes based on business requirements
4. Ensure patient support processes handle restricted accounts appropriately